

3.2 セキュリティの設計

3.2.2 データのセキュリティ

3.2.2 データのセキュリティ

学習目標とアウトライン

学習目標

- クラウド環境におけるデータセキュリティの基本的な考え方を学び、セキュリティリスクに対応する方法を理解する
- さくらのクラウドで提供されるデータセキュリティ関連の機能、サービス、および選択可能なネットワーク構成を理解する

【キーワード】

第三者機関による認証(ISO27017・ISMS・ISMAP・PCI DSS・SOC)
データ漏洩対策
マルウェア対策
データの暗号化

アウトライン

- a. さくらインターネットのセキュリティに関する取り組みを把握する
 - さくらのクラウドの第三者機関による認証
- b. データ転送時のセキュリティを検討する
 - 暗号化通信の利用
 - 接続元ネットワークの制限

アウトライン

- c. データを暗号化して保管する
 - ディスクの暗号化検討
- d. サーバとネットワークのマルウェア対策を検討する
 - マルウェア対策の検討

3.2.2 データのセキュリティ

さくらのクラウドの 第三者機関による認証

さくらのクラウドの第三者機関による認証

第三者機関による認証

- サービス提供基盤に対するセキュリティへの取り組み状況を把握し、利用者の求める要件を満たしているかどうかを確認する
- さくらインターネットは、プライバシーマーク、ISMSを取得している
- さくらのクラウドは、ISMSクラウドセキュリティを取得している。また、ISMAPに登録されている
- 石狩データセンターは、「SOC2 Type2 報告書」及び「SOC3 報告書」を監査法人より受領している

さくらのクラウドの第三者機関による認証

第三者機関による認証

- 石狩データセンターでは、カード会員データを扱う企業のファシリティサービスにおいて、クレジットカード情報を安全に取り扱うために策定されたセキュリティ基準「PCI DSS」Ver.4.0の全12要件のうち、物理的なセキュリティに関する「要件9」と「要件12」に準拠している
 - 要件9とは「カード会員データへの物理アクセスを制限」を指す
 - 要件12とは「全ての担当者の情報セキュリティに対応するポリシーを維持」を指す

さくらのクラウドの第三者機関による認証

第三者機関による認証

- ISMAPとは、政府情報システムのためのセキュリティ評価制度
- さくらのクラウドは、ISMAPのクラウドサービスリストに登録されている
- さくらのクラウドは、2023年度にデジタル庁が募集した「ガバメントクラウド整備のためのクラウドサービス」（ガバメントクラウド）に認定された。ただし、2025年度末までに技術要件をすべて満たすことを前提とした条件付きの認定となっている

3.2.2 データのセキュリティ

暗号化通信の利用

暗号化通信の利用

検討にあたっての考慮事項

- データ転送において悪意のある第三者によって通信が盗聴されるリスクを考慮して、暗号化通信を利用する。さらに、データの改ざんやなりすましのリスクにも対処するために、公的な認証局によって発行されたSSL証明書の利用を検討する
 - 一般的に、ウェブサイトとの通信では、HTTP通信をSSL/TLSで暗号化したHTTPSが使用される
 - ファイル転送においては、SSL/TLSを使用したFTPSや、SSHを使用したSFTPやSCPが一般的に使用される。求めるセキュリティレベルや利用環境に応じて適切な方法を選択する

暗号化通信の利用

検討にあたっての考慮事項

【Tips】

さくらのクラウドで標準的に利用されるSSL/TLS通信

クラウドコントロールパネルやAPIを利用する際の通信は、標準でSSL/TLSによる暗号化が実現されています。また、オブジェクトストレージも、HTTPSによる暗号化通信に対応しています。

さらに、アーカイブやISOイメージのアップロード機能では、標準でFTPS通信を使用することが可能です。

SSL証明書の利用

SSL証明書の選択

- 認証局が発行するSSL証明書には、ドメイン認証（DV）、組織認証（OV）、拡張認証（EV）の3種類がある。求める認証レベルに応じて適切なSSL証明書を選択する
 - 米国の非営利団体であるInternet Security Research Group（ISRG）が運営する認証局 Let's Encryptでは、ドメイン認証のSSL証明書のみ発行することができる
 - Let's Encrypt の証明書は、提供元のポリシーに同意することで無料で簡単に発行と登録をすることができる。時間当たりの作成数などの制限があるものの、自動更新する仕組みを入れると、管理の手間を削減することも可能となる

SSL証明書の利用

SSL証明書の管理

- ウェブサイトに対してHTTPSで通信する場合のSSL証明書の配置先としては、直接Webサーバ内に配置する選択以外に、エンハンスドロードバランサやさくらのウェブアクセラレータに登録する選択肢がある
 - エンハンスドロードバランサやウェブアクセラレータのSSL証明書を登録する機能では、利用者が用意した証明書を持ち込むだけでなく、Let's Encrypt証明書の登録と自動更新の設定も可能。特に、Webサーバの複数台構成において、各Webサーバ内で証明書を格納することなく、コントロールパネル上で一元的に管理することができる

3.2.2 データのセキュリティ

接続元ネットワークの制限

接続元ネットワークの制限

検討にあたっての考慮事項

- 悪意のある第三者により通信を盗聴や改ざんされるリスクを軽減するために、サーバと接続可能なネットワークを制限する
- クラウドリソースからサーバへ通信する際の接続元ネットワークを確認し、途中経路上のファイアウォールやパケットフィルタ、もしくはサーバOSのセキュリティ機能などを使って、不要な通信をフィルタリングすることを検討する

グローバルリソース利用時の制限

GSLBとエンハンスドロードバランサ

- **GSLBやエンハンスドロードバランサを使う場合は、それらのリソースからのみ実サーバへのアクセスを許可することを検討する**
 - 対象のリソースから実サーバに対してヘルスチェックが行われるため、ヘルスチェックの接続元ネットワークからのアクセスを許可するように設定する
 - エンハンスドロードバランサでは、オリジンガード機能によりHTTPヘッダ（X-Origin-Guard）に含まれるトークンをもとに、実サーバへのアクセスを制限できる

【Tips】

クライアントのIPアドレスによる接続制限

エンハンスドロードバランサを使用すると、実サーバへのプロキシ時にクライアント側のIPアドレスが X-Real-IP ヘッダ、および X-Forwarded-For ヘッダに付加され、実サーバにリクエストされます。特定のクライアントIPアドレスからのアクセスをブロックしたい場合など、これらのヘッダ情報をもとにサーバ側でのアクセス制御が可能です。

グローバルリソース利用時の制限

GSLBとエンハンスドロードバランサ

- GSLBの接続元ネットワークのアドレス情報は、クラウドマニュアルにて確認することができる
- エンハンスドロードバランサの接続元ネットワークのアドレス情報は、対象リソースの詳細情報の一つである「プロキシ元ネットワーク」で確認することができる

【Tips】

Syslogを有効化した場合

エンハンスドロードバランサのSyslogを有効に設定した場合、ログ転送元についても「プロキシ元ネットワーク」のアドレスとなります。Syslogサーバ側のフィルタリング設定に注意してください。

グローバルリソース利用時の制限

シンプル監視

- シンプル監視を使ってクラウドリソースを監視する場合には、シンプル監視の監視元ネットワークから監視対象までの経路上で、指定した監視方法にもとづいて発生する通信を許可する必要がある
- シンプル監視の監視元ネットワークのアドレス情報は、クラウドマニュアルにて確認することができる

さくらのウェブアクセラレータ利用時の制限

さくらのウェブアクセラレータ

- **ウェブアクセラレータを使う場合は、ウェブアクセラレータからのアクセスのみをオリジンのウェブサーバに許可することを検討する**
 - 不要なパケットをフィルタリングする方法に加えて、ウェブアクセラレータのオリジンガード機能を利用するという選択肢もある
 - オリジンがオブジェクトストレージの場合は、オブジェクトストレージのパーミッションとACLの設定を適切に行い、必要なアクセスキー以外からのアクセスを許可しない
- **ウェブアクセラレータの接続元ネットワークのアドレス情報は、クラウドマニュアルにて確認することができる**

さくらのウェブアクセラレータ利用時の制限

さくらのウェブアクセラレータ

- **アクセス制御リスト(ACL)機能を利用して、ウェブアクセラレータへのアクセスを制限することを検討する**
 - 特定のIPアドレスやCIDR範囲、または全てのアクセスのいずれかを許可または拒否することができる
 - ACLを設定する上で必要となる接続元のIPアドレス情報は、オリジンサーバのアクセスログに特定のリクエストヘッダ（X-Real-IP等）を出力することで確認できる

データベースアプライアンス利用時の制限

データベースアプライアンス

- データベースアプライアンスを使う場合は、データベースアプライアンスにて標準提供される送信元ネットワークの制限機能を利用して、特定のネットワークからのみデータベースへのアクセスを許可することを検討する

3.2.2 データのセキュリティ

ディスクの暗号化検討

ディスクの暗号化検討

検討にあたっての考慮事項

- サービス提供基盤のストレージ内でデータを暗号化して保管することを検討する。不正アクセスやシステムの不具合などによりデータ漏洩が発生した際、データ内容の閲覧や悪用されることを防ぐ。特に、クラウド上で機密性の高いデータを取り扱う場合や、データ暗号化が要件として求められる場合など、データの機密性レベルを考慮して選択する

ディスクの暗号化検討

検討にあたっての考慮事項

- さくらのクラウドで、ディスクにデータを暗号化して保存する場合は、ディスク暗号化機能を利用する
 - 暗号化と復号化の処理にかかわる計算コストや時間的遅延について、公表されているディスクのIOPSや転送帯域に影響を与えない

【Tips】

OS上のツールを使ったディスク暗号化

OS上のツールを使ってデータを暗号化する選択肢もあります。クラウドマニュアルでは、Linux系ディストリビューションで利用可能な「LUKS」によるディスク全体の暗号化について紹介されています。

ディスク暗号化機能

ディスク暗号化機能について

- **クラウド基盤内の仮想デバイスドライバによりサーバ上のディスク読み書きを暗号化・復号化するオプション機能**
 - ホストサーバ内のIOバッファや仮想ネットワーク、ストレージ装置とのネットワーク経路、ストレージ装置内に保存されるデータなど、暗号化部分の不正な窃取や流出に対する安全性を高めることができる

ディスク暗号化機能

利用時の注意事項

- **ディスク暗号化機能を利用する場合は、ディスクの新規作成時に対象ディスクに対する機能を有効化する**
 - 作成済みのディスクに対して暗号化を有効にしたり、利用途中で暗号化を無効化することはできないため注意する
 - データベースアプライアンスやNFSアプライアンスのディスク領域も暗号化できる
- **アーカイブの暗号化には対応していない**
- **ディスク暗号化機能を有効にしたディスクのアーカイブを取得することは出来ない。また、ディスク暗号化機能を有効にしたディスクに、自動バックアップを有効化することは出来ない**

オブジェクト暗号化機能

【Tips】

オブジェクトストレージの暗号化

ディスクだけでなく、オブジェクトストレージ内のオブジェクトを暗号化することもできます。オブジェクト暗号化はバケット単位で有効化し、有効化後にアップロードされたオブジェクトは、保存時に自動的に暗号化されます。これにより、保存中の情報漏洩リスクを軽減できます。

なお、暗号化を有効にする前から保管されている既存のオブジェクトは自動では暗号化されません。そのため、ストレージ内で暗号化状態の異なるオブジェクトが混在する点に注意が必要です。

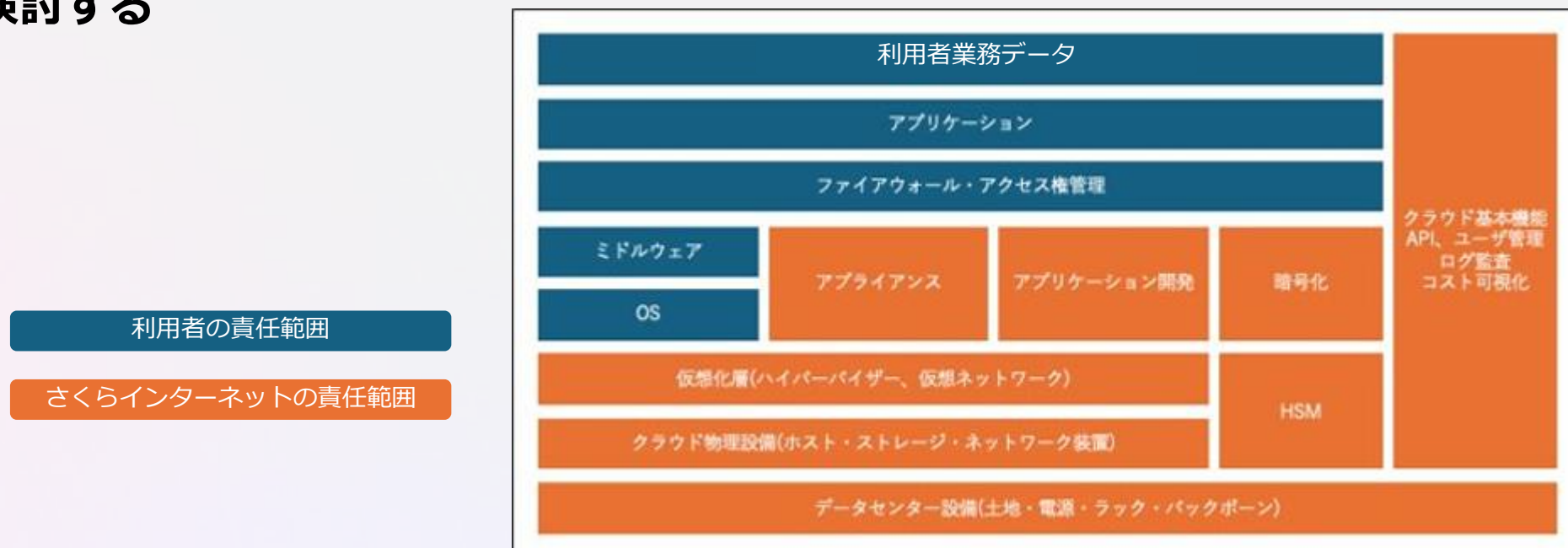
3.2.2 データのセキュリティ

マルウェア対策の検討

マルウェア対策の検討

検討にあたっての考慮事項

- サーバやネットワークに悪意のあるソフトウェアが侵入することのないように、サーバ上で動作するマルウェア対策用のソフトウェアや、ネットワークの境界で稼働させるセキュリティアプライアンスの導入を検討し、適切な対策を講じる
- サーバOSやアプリケーションのセキュリティ対策は利用者側の責任範囲であるため、サーバOSやアプリケーションを最新の状態に保つように、セキュリティアップデートの運用を検討する



マルウェア対策の検討

検討にあたっての考慮事項

- さくらのクラウドでは、マーケットプレイスで提供されているサーバセキュリティサービスを使ったマルウェア対策を検討する
 - サーバOSの標準機能を使ったマルウェア対策や、オープンソースのアンチウィルスソフトを導入する選択肢もある

【Tips】

セキュリティアプライアンス

マーケットプレイスで提供されているセキュリティアプライアンスでは、脅威検出や不正侵入検知防御（IDS/IPS）の機能を利用できます。必要に応じて導入を検討してください。

マルウェア対策の検討

検討にあたっての考慮事項

- クラウド上でデータベースを扱う際は、データベースアプライアンスの利用を検討する。
セキュリティリスクへの対応は、さくらインターネットの責任範囲となる
- さくらインターネットでは、自動化された継続的な脆弱性管理・評価のサービスを提供している。必要に応じて利用を検討する

【本スライドについてのご案内】

本スライドは、さくらインターネット株式会社により

[CC BY-SA 4.0ライセンス](#)で提供されています。

ライセンスの条件に従う限り、自由に再利用いただけますので、ぜひご活用ください。

※ 本スライドに、スライドのタイトル・著作権表示・無保証を参照する表示はありません。

※ 「制作協力：アイティーエム株式会社」「制作協力：株式会社 zero to one」との表記につきましては、クレジットとして表示していただく必要はございません。（表示していただくことも問題ございません。）



教材制作・提供：さくらインターネット株式会社

制作協力：アイティーエム株式会社

制作協力：株式会社 zero to one

【クレジット表示について】

スライドを改変せずに再利用する場合

1. 本スライドの各ページには、再利用する場合に必要な次のクレジットが予め表示されています。

This slide is licensed under [CC BY-SA 4.0](https://creativecommons.org/licenses/by-sa/4.0/) by SAKURA internet Inc.

※ 本スライドの全部をそのままお使いになる場合（本スライドのPDFファイルをそのまま再配布される場合等）や、本スライドの一部の再利用であってもクレジット表示のなされているページをそのままお使いになる場合には、重ねて同じ表示をしていただく必要はありません。

2. 印刷して再利用する場合や画像形式に変換して再利用する場合など、リンクを貼ることができない場合には、ライセンス内容が記載された次のURLをご掲載いただくか、本ページも併せてご印刷・ご掲載ください。

<https://creativecommons.org/licenses/by-sa/4.0/deed.ja>

3. 和文でクレジット表示をなされる方は、次の表示例をご参考にしてください。

本スライドは、さくらインターネット株式会社により[CC BY-SA 4.0ライセンス](https://creativecommons.org/licenses/by-sa/4.0/)で提供されています。

★上記のクレジットに加えて、合理的に実施可能な場合には、本スライドのURLか本スライドへのリンクをご掲載ください。

【クレジット表示について】

スライドを改変の上で再利用する場合

1. 改変の上で再利用される場合、次の表示例をご参考にしてください。

This [slide or document] is adapted from the slide by SAKURA internet Inc.
The slide is licensed under [CC BY-SA 4.0](#).
This [slide or document] is licensed under [CC BY-SA 4.0](#) by [Your name here].

2. 和文でクレジット表示をなされる方は、次の表示例をご参考にしてください。

本[スライド・資料等]は、さくらインターネット株式会社制作のスライドを改変の上利用しています。
同スライドは、[CC BY-SA 4.0ライセンス](#)で提供されています。
本[スライド・資料等]は、[スライド・資料等の制作者の氏名・名称]により[CC BY-SA 4.0ライセンス](#)で提供されています。

★上記のクレジットに加えて、合理的に実施可能な場合には、本スライドのURLか本スライドへのリンクをご掲載ください。